

Gestão de Identidade de Acesso

Guia de Estudos para AV2

SSO, MFA, OIDC, SAML, Auditoria, Logging, Compliance, IGA, LGPD e Integração IAM

Material didático em linguagem simples, com fluxos, exemplos, comparações e simulado.

Como usar este PDF

Leia na ordem se estiver começando do zero. Se a prova estiver perto, foque no checklist final, nos comparativos e no simulado comentado.

Fontes de estudo usadas

- Plano de Ensino - Gestão de Identidade de Acesso.
- Aula 06 - OpenID Connect (OIDC).
- Aula 07 - SAML e federação de identidade.
- Aula 08 - SSO e MFA.
- Aula 09 - Auditoria, logging e compliance.
- Revisão de base: IAM, RBAC, ABAC, PBAC, LDAP e Kerberos.

Sumário

- 1. Visão geral da AV2
- 2. Revisão: identidade, autenticação e autorização
- 3. OAuth 2.0 e OIDC
- 4. Tokens, JWT e validações
- 5. SAML e federação de identidade
- 6. SAML vs OIDC
- 7. Claims, atributos e autorização
- 8. SSO e gestão de sessão
- 9. MFA, FIDO2/WebAuthn e autenticação baseada em risco
- 10. Auditoria, logging, SIEM e compliance
- 11. Governança de identidades (IGA)
- 12. Privacidade, LGPD e minimização de dados
- 13. Ferramentas IAM
- 14. Integração IAM com aplicações
- 15. Comparativos essenciais
- 16. Simulado comentado
- 17. Checklist final da AV2

1. Visão geral da AV2

A AV2 cobre a parte mais corporativa e prática de IAM. Na AV1, a base era entender identidade digital, autenticação, autorização e modelos de controle de acesso. Na AV2, a pergunta muda: como uma empresa real permite login único, protege contas críticas, registra eventos e prova conformidade?

A ideia central é conectar várias peças: IdP, SSO, MFA, protocolos de federação, claims, políticas, logs, SIEM, governança e privacidade.

Empresa real

- Usuários e grupos no diretório
- IdP centralizado
- Apps SaaS, cloud, APIs e sistemas internos
- SSO com SAML/OIDC
- MFA para reduzir risco de roubo de senha
- Logs centralizados
- SIEM para correlação
- Governança para revisar e remover acessos

Ideia-chave

IAM não é apenas tela de login. IAM é o conjunto de políticas, processos e tecnologias para controlar quem acessa o quê, em qual contexto, com qual evidência e por quanto tempo.

O que costuma cair

- Diferença entre OAuth 2.0 e OIDC.
- Função do ID Token, Access Token e Refresh Token.
- Fluxos de autenticação e federação: Authorization Code, SAML SP-Initiated e IdP-Initiated.
- Validação de tokens/assertions: assinatura, audience, issuer, expiração, recipient e nonce.
- SSO, sessão do IdP, sessão local e Single Logout.
- MFA, riscos de SMS/e-mail, FIDO2/WebAuthn e autenticação resistente a phishing.
- Risk-Based Authentication: IP, geolocalização, impossible travel e dispositivo.
- Auditoria: o que logar, pipeline de logs, NTP, SIEM, WORM e correlação.
- IGA: ciclo de vida joiner/mover/leaver, recertificação, privilege creep e SoD.
- LGPD: minimização de dados, retenção, proteção de logs e claims.

2. Revisão: identidade, autenticação e autorização

Antes de SAML, OIDC e SSO, três conceitos precisam estar claros.

Conceito	Pergunta que responde	Exemplo
Identidade	Quem ou o que está sendo representado?	Usuário, aplicação, serviço, dispositivo.
Autenticação	Quem é você?	Senha, MFA, biometria, certificado, chave física.
Autorização	O que você pode fazer?	Ler dados, editar recurso, fazer deploy, aprovar pagamento.

A autenticação não concede permissão automaticamente. Ela apenas confirma a identidade. Depois disso, o sistema precisa aplicar regras de autorização.

João fez login com sucesso.
Isso prova que ele é João.
Mas João pode acessar o financeiro?
Depende de papéis, atributos, políticas e contexto.

Em IAM, a identidade pode ter vários componentes: identificador, credenciais, atributos e contexto.

- Identificador: login, e-mail, ID ou subject do token.
- Credenciais: senha, certificado, token, chave de segurança.
- Atributos: cargo, departamento, grupo, papel, nível de autorização.
- Contexto: horário, localização, dispositivo, rede, risco do IP.

3. OAuth 2.0 e OpenID Connect (OIDC)

3.1 O problema da web moderna

No modelo antigo, cada aplicação mantinha seu próprio cadastro e senha. Isso gera reutilização de senha, vazamentos, dificuldade de offboarding e experiência ruim.

Sem federação:

Sistema A -> senha própria

Sistema B -> senha própria

Sistema C -> senha própria

Com IAM:

Usuário -> IdP central -> tokens/assertions -> vários sistemas

3.2 OAuth 2.0 não é autenticação

OAuth 2.0 é um framework de autorização. Ele permite que uma aplicação acesse recursos em nome do usuário, sem receber a senha do usuário.

Papel no OAuth	Função
Resource Owner	Dono do recurso, geralmente o usuário.
Client	Aplicação que solicita acesso.
Authorization Server	Servidor que autentica, obtém consentimento e emite tokens.
Resource Server	API ou serviço onde está o recurso protegido.

Pegadinha de prova

OAuth 2.0 sozinho não prova identidade. Ele autoriza acesso a recursos. Para autenticação padronizada, usamos OIDC.

3.3 Authorization Code Flow

É o fluxo mais recomendado para aplicações web com backend e também para aplicações modernas usando PKCE. O token não é entregue diretamente ao navegador; primeiro o client recebe um código temporário.

1. Usuário acessa a aplicação.

2. Aplicação redireciona o usuário para o Authorization Server/IdP.
3. Usuário autentica e consente.
4. Authorization Server redireciona de volta com um authorization code.
5. Backend troca o code por tokens.
6. Aplicação valida os tokens e cria sessão local.

```
GET /auth?
  response_type=code
  client_id=CLIENT_ID
  redirect_uri=https://meuapp.com/callback
  scope=openid profile email
  state=valor_anti_csrf
  code_challenge=hash_pkce
  code_challenge_method=S256
```

O parâmetro state ajuda contra CSRF. O PKCE ajuda a evitar que um authorization code interceptado seja usado por outra aplicação.

3.4 Implicit Flow

É um fluxo legado em que o token era retornado diretamente no navegador. Hoje não é recomendado, pois aumenta o risco de vazamento do token. Em SPAs modernas, prefira Authorization Code + PKCE.

3.5 Client Credentials

É usado para comunicação máquina-com-máquina, sem usuário humano.

```
Exemplo:
Backend de pagamentos -> API antifraude
Microserviço A -> Microserviço B
Job agendado -> API interna
```

O client se autentica com client_id e client_secret, recebe um access token e chama a API.

3.6 OIDC: autenticação em cima do OAuth

OpenID Connect adiciona identidade ao OAuth. OIDC usa os fluxos do OAuth, mas acrescenta o escopo openid e emite um ID Token.

OAuth 2.0	OIDC
Autorização	Autenticação + identidade
Access Token	ID Token + Access Token
Permite acessar API/recurso	Prova que o usuário autenticou
Ex.: app pode ler Drive	Ex.: usuário João logou às 14h

```
scope=openid profile email
```

```
openid -> quero fluxo OIDC
profile -> quero claims de perfil
email -> quero e-mail e email_verified
```

4. Tokens, JWT e validações

4.1 ID Token

O ID Token é o artefato de identidade. Ele é destinado ao client, ou seja, à aplicação que pediu o login. Normalmente é um JWT.

```
{
  "iss": "https://accounts.google.com",
  "sub": "105029304928304928304",
  "aud": "CLIENT_ID_APP",
  "iat": 1712521308,
  "exp": 1712524908,
  "name": "Alex Silva",
  "email": "alex@exemplo.com",
  "email_verified": true
}
```

Claim	Significado
iss	Issuer: quem emitiu o token.
sub	Subject: identificador único e estável do usuário.
aud	Audience: aplicação para a qual o token foi emitido.
iat	Issued At: quando foi emitido.
exp	Expiration: quando expira.
auth_time	Quando o usuário realmente autenticou.
nonce	Valor aleatório usado para evitar replay em autenticação.

4.2 Access Token

O Access Token serve para acessar APIs e recursos protegidos. Ele não deve ser tratado como documento principal de identidade do usuário dentro do client.

```
GET /userinfo
Authorization: Bearer ACCESS_TOKEN
```

4.3 Refresh Token

O Refresh Token permite obter novos access tokens sem pedir senha novamente. Por ser sensível, precisa ser armazenado com cuidado, rotacionado e revogado quando houver suspeita de ataque.

Access Token: vida curta, usado para chamar API.
Refresh Token: vida mais longa, usado para renovar access tokens.
ID Token: prova de autenticação para o client.

4.4 JWT: Header, Payload e Signature

Um JWT tem três partes separadas por pontos.

```
header.payload.signature
```

- Header: algoritmo e identificador da chave, como alg=RS256 e kid=chave123.
- Payload: claims, como sub, iss, aud, exp, email e role.
- Signature: assinatura digital que protege contra alteração do token.

Se um atacante alterar uma claim, por exemplo role=user para role=admin, a assinatura deve se tornar inválida. Por isso, o client deve validar a assinatura antes de confiar no token.

4.5 Checklist de validação do ID Token

- Verificar assinatura usando a chave pública correta do provedor.
- Validar iss: o emissor é o IdP esperado?
- Validar aud: o token foi emitido para minha aplicação?
- Validar exp: o token ainda está dentro do prazo?
- Validar nonce quando aplicável.
- Validar iat/auth_time quando a ação exigir login recente.
- Não aceitar algoritmo inseguro ou diferente do esperado.
- Não confiar em token recebido sem verificar assinatura e audiência.

5. SAML e federação de identidade

5.1 O problema das ilhas de identidade

Em empresas, várias aplicações podem manter usuários separados: Slack, AWS, Jenkins, GitHub, sistema financeiro e VPN. Isso dificulta governança e offboarding, além de aumentar o risco de reutilização de senhas.

Federação de identidade significa que um sistema confia na autenticação feita por outro sistema.

Slack não precisa guardar a senha corporativa.
Slack confia no IdP, como Entra ID, Okta, ADFS ou Keycloak.

5.2 Componentes do SAML

Componente	Função
User Agent	Navegador do usuário. Transporta mensagens entre IdP e SP.
IdP	Identity Provider. Autentica o usuário e assina a assertion.
SP	Service Provider. Aplicação final que concede acesso.
SAML Assertion	Documento XML assinado que atesta a identidade e atributos.
Metadata	Contrato de confiança com EntityID, endpoints e certificados.
ACS URL	Endpoint do SP que recebe a resposta SAML.
EntityID	Identificador único do IdP ou SP dentro da federação.

5.3 Metadata e contrato de confiança

Antes do login funcionar, IdP e SP precisam trocar metadados. Eles dizem: quem sou eu, para onde enviar mensagens e com qual chave validar assinaturas.

- EntityID: identificador único do participante.
- SSO URL: endpoint do IdP para iniciar autenticação.
- ACS URL: endpoint do SP para receber a SAMLResponse.
- Certificado público: usado pelo SP para validar a assinatura do IdP.
- HTTPS: necessário para proteger o transporte.

5.4 SAML Assertion

A Assertion é o pacote da verdade. Ela é um XML assinado que afirma quem é o usuário, quem emitiu, quando vale, para qual SP vale e quais atributos o usuário possui.

```
SAML Assertion
├─ Issuer: quem emitiu
├─ Subject/NameID: quem é o usuário
├─ Conditions: validade e restrições
├─ AudienceRestriction: para qual SP vale
├─ AuthnStatement: como/quando autenticou
└─ AttributeStatement: role, departamento, grupos, e-mail etc.
```

O SP não confia na senha do usuário. Ele confia na assinatura da Assertion emitida pelo IdP.

5.5 Fluxo SP-Initiated

É o fluxo mais comum. Começa quando o usuário tenta acessar diretamente o serviço, como Slack, AWS ou Jenkins.

7. Usuário acessa o SP.
8. SP percebe que não há sessão local.
9. SP gera uma AuthnRequest.
10. Navegador redireciona o usuário para o IdP.
11. IdP autentica o usuário e pode exigir MFA.
12. IdP gera uma SAML Assertion assinada.
13. Navegador envia a SAMLResponse para a ACS URL do SP via HTTP POST.
14. SP valida assinatura, audience, recipient e validade temporal.
15. SP cria sessão local e concede acesso.

5.6 Fluxo IdP-Initiated

Começa no portal do IdP. O usuário entra no dashboard do IdP e clica no ícone de uma aplicação. O IdP envia a Assertion diretamente para o SP, sem AuthnRequest prévio.

Atenção

IdP-Initiated é conveniente, mas exige cuidado porque pode envolver resposta não solicitada. O SP deve validar audience, recipient, assinatura e tempo com rigor.

5.7 Bindings: Redirect e POST

Binding	Uso comum	Como funciona
HTTP Redirect	Envio do AuthnRequest ao IdP.	Dados compactados/codificados na URL e redirecionamento 302.

HTTP POST	Envio da SAMLResponse ao SP.	Formulário HTML automático com campo SAMLResponse.
-----------	------------------------------	--

5.8 Segurança em SAML

- Assinatura digital: impede alteração da Assertion sem quebrar a validação.
- NotBefore e NotOnOrAfter: limitam a janela de validade e reduzem replay.
- AudienceRestriction: token emitido para um SP não deve valer para outro.
- Recipient: garante que a resposta foi enviada ao endpoint ACS correto.
- NTP: relógios desalinhados causam falhas e abrem risco de replay.
- Response Wrapping: ataque em XML no qual a app valida uma parte assinada, mas lê outra parte injetada.

Response Wrapping em uma frase

O atacante injeta um elemento XML malicioso, a biblioteca valida a parte assinada legítima, mas a aplicação lê o elemento falso. Pode causar bypass ou escalção de privilégio.

6. SAML vs OIDC

Critério	SAML	OIDC
Formato	XML	JSON/JWT
Uso comum	Enterprise, SaaS corporativo, sistemas legados	Apps modernos, mobile, SPA, APIs
Artefato principal	SAML Assertion	ID Token
Transporte	HTTP Redirect/POST via navegador	Fluxos OAuth 2.0
Assinatura	XML Signature	JWT Signature
Facilidade para dev web	Mais complexo	Mais simples
Quando escolher	Integração corporativa legada ou SaaS enterprise	Aplicações novas, APIs e mobile

Resumo:

SAML = XML + federação corporativa tradicional.

OIDC = JSON/JWT + autenticação moderna sobre OAuth.

OAuth = autorização, não autenticação.

7. Claims, atributos e autorização

Saber que João logou não basta. A aplicação precisa saber o que João pode fazer. Para isso, IdP envia claims ou atributos.

Claims possíveis:

sub=12345

email=joao@empresa.com

department=Financeiro

role=Manager

groups=[financeiro, aprovadores]

7.1 Mapeamento de claims

Sistemas diferentes usam nomes diferentes para atributos. O IdP pode enviar department=Sales, mas o CRM pode esperar grupo_crm=Vendas. O mapeamento traduz essas informações.

```
department=Sales -> role_crm=SalesUser  
role=Manager -> permissao=aprovar_relatorio  
group=DevOps -> acesso=JenkinsConfigure
```

7.2 Claims com RBAC e ABAC

Se a aplicação usa uma claim role=Admin para decidir acesso, está usando uma lógica próxima de RBAC. Se usa departamento, horário, localização, dispositivo e classificação do recurso, está usando uma lógica mais próxima de ABAC.

```
Exemplo ABAC:  
Permitir editar relatório se:  
  departamento = Financeiro  
  AND cargo = Gerente  
  AND ação = escrita  
  AND dispositivo = gerenciado  
  AND horário entre 08:00 e 18:00
```

8. SSO e gestão de sessão

8.1 O que é SSO

Single Sign-On é login único. O usuário autentica uma vez no IdP e acessa vários sistemas sem repetir senha.

```
Usuário -> IdP  
Depois acessa:  
  Slack  
  AWS  
  GitHub  
  Jenkins  
  Sistema financeiro  
sem digitar senha em cada aplicação.
```

8.2 Como o SSO silencioso funciona

16. Usuário acessa App A.
17. App A redireciona para o IdP.
18. Usuário autentica.
19. IdP cria cookie de sessão no domínio do IdP.
20. Usuário acessa App B.
21. App B redireciona para o IdP.

- 22. Navegador envia automaticamente o cookie do IdP.
- 23. IdP reconhece o usuário e emite novo token/assertion sem pedir senha novamente.

8.3 Sessão do IdP vs sessão da aplicação

A sessão do IdP indica que o usuário está autenticado no provedor central. A sessão local do SP é criada por cada aplicação após validar token/assertion.

Sessão do IdP: usuário está logado no provedor central.
Sessão do Slack: usuário está logado no Slack.
Sessão do Jenkins: usuário está logado no Jenkins.

8.4 Single Logout (SLO)

SLO tenta encerrar todas as sessões conectadas. É importante para segurança, principalmente em dispositivos compartilhados, mas é difícil de implementar perfeitamente.

- Apps têm tempos de expiração diferentes.
- Navegadores bloqueiam cookies de terceiros.
- Alguns SPs não implementam logout corretamente.
- Podem existir sessões órfãs ativas mesmo após logout em outro lugar.

9. MFA, FIDO2/WebAuthn e autenticação baseada em risco

9.1 Por que MFA é essencial em SSO

SSO melhora a experiência, mas cria uma conta mestre. Se a senha do IdP for roubada, o atacante pode acessar muitos sistemas. MFA reduz esse risco.

Fator	Significado	Exemplos
Conhecimento	Algo que você sabe	Senha, PIN
Posse	Algo que você tem	Celular, app autenticador, smartcard, chave física
Inerência	Algo que você é	Digital, face, íris

9.2 SMS e e-mail: melhor que nada, mas fracos

- SMS pode sofrer SIM Swap.
- Códigos podem ser pescados por phishing em tempo real.
- E-mail pode estar comprometido junto com a conta principal.
- Usuário pode entregar o OTP voluntariamente em site falso.

Phishing de OTP:

1. Usuário acessa site falso.
2. Digita senha.
3. Site falso pede código SMS.
4. Atacante usa o código no site verdadeiro em tempo real.

9.3 FIDO2 e WebAuthn

FIDO2/WebAuthn usa criptografia de chave pública. O servidor armazena a chave pública; a chave privada fica no dispositivo do usuário e nunca sai dele.

24. Usuário registra uma credencial no site.
25. Dispositivo cria par de chaves.
26. Servidor guarda a chave pública.
27. No login, servidor envia um desafio.
28. Dispositivo assina o desafio com a chave privada.
29. Servidor valida com a chave pública.

Por que é resistente a phishing?

A credencial é vinculada ao domínio. Se foi criada para empresa.com, o navegador não assina login para um domínio falso. Além disso, não há código para o usuário copiar e colar.

9.4 Risk-Based Authentication

Autenticação baseada em risco avalia sinais contextuais antes de liberar, desafiar ou bloquear o acesso.

Sinal	Exemplo de uso
IP	IP residencial confiável vs proxy/datacenter suspeito.
Geolocalização	País incomum pode exigir MFA.
Impossible Travel	Login em São Paulo às 10h e Londres às 11h.
Dispositivo	Dispositivo gerenciado pela empresa vs pessoal inseguro.
Horário	Acesso de madrugada fora do padrão.
Reputação	IP associado a botnet, Tor ou força bruta.

Decisão em tempo real:

Baixo risco -> libera.

Risco médio -> exige MFA/biometria.

Alto risco -> bloqueia e alerta o SOC.

10. Auditoria, logging, SIEM e compliance

A autenticação responde como entrar. Auditoria responde o que foi feito depois. Logs são a memória persistente do IAM.

10.1 O que um log de IAM deve registrar

Campo	Exemplo
Quem	sub=123, joao@empresa.com, user_id interno
Quando	Timestamp em ISO 8601/UTC
Onde	IP, geolocalização aproximada, rede, VPN
Dispositivo	User-Agent, SO, postura de segurança
Recurso	Jenkins pipeline, AWS role, sistema financeiro
Ação	Login, leitura, escrita, exclusão, alteração de permissão
Resultado	Sucesso, falha, negado, erro
Motivo	MFA falhou, política negou, token expirado

10.2 Eventos críticos

- Login bem-sucedido e falhas consecutivas.

- Reset de senha e troca de MFA.
- Criação, alteração e desativação de usuários.
- Atribuição ou remoção de roles/grupos.
- Elevação de privilégio, sudo/runas e uso de contas admin.
- Alteração em pipelines, políticas e configurações críticas.
- Acesso, exportação ou exclusão de dados sensíveis.

10.3 Logs de aplicação vs infraestrutura

Tipo	Foco	Exemplo
Aplicação	Regra de negócio	Aprovar pagamento, alterar salário, exportar relatório.
Infraestrutura	Acesso técnico	SSH, RDP, VPN, sudo, firewall, sistema operacional.

10.4 Timestamp, NTP e ordem dos eventos

Sem relógios sincronizados, uma investigação perde confiabilidade. O IdP, o SP, os servidores e o SIEM precisam usar horário consistente. NTP ajuda a manter a cronologia correta.

Boas práticas:

- Usar ISO 8601, preferencialmente UTC.
- Diferenciar tempo de ocorrência e tempo de ingestão.
- Sincronizar servidores com NTP.
- Considerar clock skew em SAML/OIDC.

10.5 Pipeline de logs

Sistema gera log

- > agente coleta
- > transporte seguro
- > normalização
- > enriquecimento com contexto
- > armazenamento central
- > SIEM correlaciona
- > alertas, dashboards e relatórios

O enriquecimento adiciona contexto, como departamento do usuário, criticidade do recurso, país do IP e score de risco.

10.6 Imutabilidade e WORM

Logs de auditoria precisam ser protegidos contra alteração. WORM significa Write Once, Read Many: escreve uma vez, lê muitas, mas não altera durante o período de retenção.

- Evita que um administrador apague o próprio rastro.
- Ajuda em perícia e conformidade.
- Pode usar hash e assinatura digital para verificar integridade.
- Deve ter retenção compatível com política e legislação.

10.7 SIEM e correlação de eventos

SIEM centraliza logs de várias fontes e transforma eventos isolados em uma linha do tempo de segurança.

Exemplo de correlação:

1. Login suspeito no LDAP fora do horário.
2. Mesmo usuário altera pipeline no Jenkins.
3. SIEM conecta os eventos.
4. Resposta: revogar token, bloquear conta e alertar SOC.

10.8 Compliance

Compliance é provar que políticas, normas e leis foram seguidas. O auditor quer evidências: quem acessou, quando, por que, com qual aprovação e se o acesso foi revisado.

11. Governança de identidades (IGA)

IAM foca autenticação e controle de acesso. IGA foca governança: ciclo de vida, revisão, aprovação, auditoria e conformidade dos acessos.

IAM	IGA
Como autenticar e autorizar?	Quem deve ter acesso e quem aprovou?
Login, token, MFA, SSO	Recertificação, SoD, ciclo de vida, auditoria
Controle operacional	Governança e conformidade

11.1 Joiner, Mover, Leaver

Fase	O que acontece	Risco se falhar
Joiner	Criar conta, grupos, roles e MFA para novo colaborador.	Usuário sem acesso ou com acesso excessivo.
Mover	Atualizar acessos ao mudar de cargo/departamento.	Manter privilégios antigos e acumular acesso.
Leaver	Desativar conta, revogar tokens, encerrar sessões e remover grupos.	Conta zumbi e exfiltração de dados.

11.2 Recertificação de acesso

É a revisão periódica dos acessos. O gestor confirma se o usuário ainda precisa daquele acesso. Se não precisar, o acesso deve ser removido e a evidência registrada.

11.3 Privilege Creep

Privilege Creep é o acúmulo de privilégios ao longo do tempo, geralmente por mudanças de função sem remoção de acessos antigos.

Ano 1: João era Suporte -> acesso de suporte.
Ano 2: João virou DevOps -> acesso de DevOps.
Ano 3: João foi para Segurança -> acesso de segurança.
Se nada for removido, João acumula tudo.

11.4 Separação de Deveres (SoD)

SoD evita que uma única pessoa controle um processo crítico de ponta a ponta.

Exemplo financeiro:
Pessoa A cria fornecedor.
Pessoa B aprova fornecedor.
Pessoa C autoriza pagamento.

Combinação tóxica:
Criador + Aprovador na mesma pessoa.

- Criador + aprovador é risco de fraude.
- Auditor + administrador é conflito de interesse.
- Desenvolvedor + deploy direto em produção pode quebrar governança.
- Contas temporárias devem ter prazo e revisão.

12. Privacidade, LGPD e minimização de dados

IAM protege dados, mas também coleta dados pessoais e sensíveis ao contexto: e-mail, IP, localização aproximada, cargo, departamento, dispositivo e histórico de acesso. Por isso, a arquitetura deve respeitar minimização, segurança e retenção adequada.

12.1 Claims demais viram risco

Exemplo ruim de token:

```
{
  "sub": "123",
  "email": "joao@empresa.com",
  "cpf": "000.000.000-00",
  "salario": "10000",
  "role": "user"
}
```

Exemplo melhor:

```
{
  "sub": "123",
  "email": "joao@empresa.com",
  "role": "user"
}
```

Regra prática

Token não é banco de dados. Log não é depósito livre de dados pessoais. Envie e registre apenas o necessário para autenticação, autorização, auditoria e segurança.

12.2 Boas práticas

- Minimizar claims em tokens e assertions.
- Proteger logs em trânsito e em repouso.
- Controlar quem pode consultar logs e relatórios.
- Definir retenção e descarte conforme política e necessidade legal.
- Evitar dados pessoais em URLs.
- Pseudonimizar quando possível.

- Registrar finalidade e base de uso para dados de auditoria.

13. Ferramentas IAM: mercado e open source

13.1 Mercado

Ferramenta	Uso típico
Microsoft Entra ID	IdP corporativo, SSO, MFA, acesso condicional.
Okta	IdP, SSO, MFA, integração com SaaS.
Ping Identity	Federação, SSO enterprise.
AWS IAM / IAM Identity Center	Acesso a recursos AWS, roles e políticas.
Google Cloud IAM	Controle de acesso em recursos GCP.
CyberArk	PAM, vaulting e contas privilegiadas.
Duo	MFA e verificação de dispositivo.

13.2 Open source

Ferramenta	Uso típico
Keycloak	IdP open source com OIDC, OAuth2 e SAML.
FreeIPA	Identidade para Linux com LDAP, Kerberos e DNS.
OpenLDAP	Diretório de usuários, grupos e atributos.
MIT Kerberos	Autenticação baseada em tickets.
Wazuh	SIEM/XDR open source para logs e segurança.
Open Policy Agent	Motor de políticas para PBAC/ABAC.
Authentik/Authelia	SSO e autenticação para aplicações self-hosted.

14. Integração IAM com aplicações

Ao integrar uma aplicação com IAM, a aplicação não deve reinventar login e senha se já existe IdP. Ela deve delegar autenticação ao IdP, validar tokens/assertions e aplicar autorização com base em claims/políticas.

14.1 Fluxo genérico de integração

30. Aplicação detecta que não há sessão local.
31. Redireciona o usuário para o IdP.
32. IdP autentica e aplica MFA/acesso condicional.
33. IdP devolve ID Token/OIDC ou SAML Assertion.
34. Aplicação valida assinatura, issuer, audience, expiração e demais campos.
35. Aplicação cria sessão local segura.
36. Aplicação usa claims para autorização.
37. Aplicação registra logs de login, ação e resultado.
38. Logout, expiração e revogação são tratados corretamente.

14.2 Integração OIDC

- Usar Authorization Code + PKCE.
- Configurar client_id, redirect_uri e scopes.
- Validar ID Token antes de criar sessão.
- Usar Access Token para UserInfo ou APIs.
- Checar iss, aud, exp, assinatura e nonce.
- Não armazenar tokens sensíveis de forma insegura.

14.3 Integração SAML

- Configurar metadata do IdP e do SP.
- Definir EntityID e ACS URL corretamente.
- Validar XML Signature.
- Validar AudienceRestriction, Recipient e validade temporal.
- Ler atributos autorizados.
- Criar sessão local e registrar log.

14.4 Exemplo corporativo completo

Empresa ACME
IdP: Microsoft Entra ID
Apps: Slack, AWS, Jenkins
MFA: FIDO2 para admins, app autenticador para usuários comuns
SIEM: centraliza logs

Fluxo:

1. João acessa Jenkins.
2. Jenkins redireciona para o IdP.
3. IdP exige MFA.
4. IdP envia token/assertion com groups=Developers.
5. Jenkins permite executar build, mas não editar pipeline.
6. Log é enviado ao SIEM.

15. Comparativos essenciais para decorar

Tema	Resumo
Autenticação vs autorização	Autenticação confirma quem é. Autorização decide o que pode fazer.
OAuth vs OIDC	OAuth autoriza acesso. OIDC autentica e entrega identidade.
ID Token vs Access Token	ID Token é para o client saber quem logou. Access Token é para APIs.
SAML vs OIDC	SAML usa XML e é comum em enterprise/legado. OIDC usa JSON/JWT e é moderno.
Sessão vs token	Sessão é estado de login. Token é artefato assinado com validade e claims.
SMS vs FIDO2	SMS pode sofrer phishing/SIM Swap. FIDO2 é resistente a phishing.
IAM vs IGA	IAM opera acesso. IGA governa, revisa e audita acesso.
RBAC vs ABAC vs PBAC	RBAC usa papéis. ABAC usa atributos. PBAC centraliza políticas em um motor.

16. Simulado comentado

1. Explique por que OAuth 2.0 não é autenticação e como OIDC resolve isso.

Resposta esperada: OAuth 2.0 é autorização: permite que uma aplicação acesse recursos em nome do usuário por meio de access tokens. Ele não garante identidade. OIDC adiciona autenticação sobre OAuth usando scope=openid e ID Token com claims como sub, iss, aud e exp.

2. Explique o fluxo SP-Initiated no SAML.

Resposta esperada: O usuário acessa o SP, que gera AuthnRequest e redireciona ao IdP. O IdP autentica o usuário, emite SAML Assertion assinada e envia ao ACS do SP. O SP valida assinatura, audience, recipient e tempo, cria sessão local e libera acesso.

3. Por que MFA é essencial em SSO?

Resposta esperada: SSO centraliza acesso. Se a senha da conta mestre vaza, vários sistemas ficam expostos. MFA adiciona uma camada extra. Para contas críticas, métodos resistentes a phishing, como FIDO2/WebAuthn, são preferíveis.

4. O que é Response Wrapping em SAML?

Resposta esperada: É um ataque em XML em que o invasor injeta elementos não cobertos pela assinatura. A biblioteca pode validar a parte assinada, enquanto a aplicação lê a parte falsa. Pode causar bypass ou escalção. Defesa: validar assinatura corretamente e usar exatamente o elemento assinado.

5. O que deve aparecer em um log de IAM?

Resposta esperada: Subject/usuário, timestamp, IP, geolocalização aproximada, dispositivo/user-agent, recurso, ação, resultado e motivo. Eventos críticos incluem login, falhas, reset de senha, troca de MFA, alteração de permissões e elevação de privilégio.

6. Explique SIEM e correlação de eventos.

Resposta esperada: SIEM centraliza logs de múltiplas fontes e gera alertas. Correlação conecta eventos isolados, como login suspeito no LDAP e alteração de pipeline no Jenkins pelo mesmo usuário, formando uma linha do tempo de incidente.

7. O que é recertificação de acesso?

Resposta esperada: É a revisão periódica dos acessos para verificar se ainda são necessários e compatíveis com o cargo. Remove privilégios excessivos e gera evidência de conformidade.

8. Explique privilege creep e SoD.

Resposta esperada: Privilege creep é o acúmulo de acessos antigos após mudanças de cargo. SoD separa deveres para que uma pessoa não controle processo crítico de ponta a ponta, como criar e aprovar pagamento.

17. Checklist final da AV2

- Sei explicar que OAuth 2.0 é autorização, e OIDC é autenticação em cima do OAuth.
- Sei explicar Authorization Code + PKCE.
- Sei diferenciar ID Token, Access Token e Refresh Token.
- Sei validar JWT: assinatura, iss, aud, exp e nonce.
- Sei explicar SAML com IdP, SP, User Agent, Assertion, metadata, ACS e EntityID.
- Sei explicar o fluxo SP-Initiated.

- Sei comparar SAML vs OIDC.
- Sei explicar claims e mapeamento de atributos.
- Sei explicar SSO, cookie de sessão do IdP, sessão local e Single Logout.
- Sei justificar por que SSO precisa de MFA.
- Sei diferenciar SMS/e-mail de FIDO2/WebAuthn.
- Sei explicar Risk-Based Authentication e impossible travel.
- Sei listar o que deve ser logado em IAM.
- Sei explicar timestamp, NTP e replay.
- Sei explicar pipeline de logs, SIEM, correlação e WORM.
- Sei explicar IGA, joiner/mover/leaver, recertificação, privilege creep e SoD.
- Sei conectar IAM com LGPD: minimização, retenção, proteção de logs e claims.
- Sei desenhar um fluxo completo de integração IAM com uma aplicação.

Mensagem final

Na prova, responda sempre conectando conceito + motivo + fluxo + risco + exemplo. Isso mostra que você entendeu a arquitetura, não apenas decorou siglas.